VULNERABILITY ASSESSMENT REPORT

Report Information	Details
Organisation	Techbridge Consulting Firm
Assessment Title	Capstone Project
Assessment Type	Web Application & APK
Assessment Period	
Prepared By	Madu Kevin- Vulnerability Management Analyst
Classification	Confidential use only

CONFIDENTIAL

HANDLING NOTICE:

This report may contain sensitive information about security weaknesses, affected assets, and remediation activities. Distribute it only to authorized personnel.

1. EXECUTIVE SUMMARY

Assessment Overview: The Assets assessed in this report were-

- Techbridge's Legacy Web Services Environment
- Techbridge's Customer Mobile Application
- Techbridge's Digital Banking Application

Overall Risk: HIGH

TOP 10 VULNERABILITIES AND REMEDIATION PLANS:

Techbridge Asset	Vulnerability	Severity	Remediation actions
Web Services	Obsolete end of life server stack	Critical	Migrate immediately to modern supported versions
Web Services	SQL injection vulnerability	Critical	Update app to use parameterised queries
Customer Mobile App	No stack canary value added to 4 binary stacks	High	Update app build configurations to turn on stack protection
Digital Bank App	Debug configuration enabled	High	Ensure that release builds explicitly disable debugging
Web services	OpenSSL CCS injection	High	Deploy OpenSSL patches
Digital Banking App	Insecure "webview" implementation	High	Default to rejecting mistakes by invoking "handler.cancel()"
Digital Banking App	Cleartext traffic enabled for app	High	Enforce secure network traffic(https,ftps)
Customer mobile app	Cleartext traffic enabled for app	High	Enforce secure network traffic (https,ftps)
Web services	Directory traversal vulnerability	High	Contact vendor for patch or upgrade
Web services	Web server transmits	High	Make sure that every sensitive

	cleartext credentials		form transmits content over HTTPS.

PRODUCTION RELEASE RECOMMENDATION:

1. Techbridge Web Service: DO NOT APPROVE, End of life server stack and SQL injection vulnerability presents an unacceptable risk that must be remediated immediately before further review for potential release.
2. Customer Mobile Application: CONDITIONAL APPROVAL, Release may proceed after stack protection update and secure network traffic implementation.
3. Digital banking application: DO NOT APPROVE, remediation for the multiple vulnerabilities found must be implemented first and then further review of the application before potential release.

2. ASSESSMENT OBJECTIVES:

Identify, validate, prioritise and communicate vulnerability exposure before a planned production release.

3. SCOPE:

In scope activities:

- Network enumeration and service discovery.
- Vulnerability scanning.
- Web vulnerability scanning.
- Mobile application static analysis.
- Manual validation of selected findings.
- Collection of evidence.
- Limited interaction required to establish that a vulnerability exists.

Out of scope activities:

- Denial-of-service or resource-exhaustion testing.
- Destructive exploitation.
- Deletion or unauthorised alteration of data.
- Persistence mechanisms or malware deployment.
- Attacks against systems outside the supplied lab scope.

• Scanning or testing public Internet targets.

• Social engineering.

• Credential attacks against external services.

4. METHODOLOGY:

- Execution Techniques: Hybrid (automated vulnerability scanners and manual verification), Active probing.
- Testing environment: 1 Web Application, 2 Android Applications
- Standards/Frameworks:

• UK General Data Protection Regulation (UK GDPR)

• Data Protection Act 2018

• Applicable Financial Conduct Authority (FCA) requirements

• FCA operational resilience expectations

• PCI DSS obligations where cardholder data is processed

• Contractual security obligations with banking and payment partners

- Tools: Nmap, Tenable Nessus, Owaspzap, Nikto, Mobsf.

5. RISK RATING METHODOLOGY

SEVERITY	TYPICAL CRITERIA	RECOMMENDED RESPONSE
Critical	Severe compromise, Major data loss, significant business impact	Immediate remediation and controls
High	Significant Risk	Urgent remediation
Medium	Meaningful weakness with limited/conditional impact	Planned remediation
Low	Limited impact	Routine improvement

6. SUMMARY OF FINDINGS:

ID	FINDING	ASSET	SEVERITY	CVSS	STATUS
V-001	Obsolete server stack	Techbridge web service	critical	10.0	closed
V-002	SQL injection	Techbridge web service	critical	9.3	closed
V-003	Web server transmits cleartext credentials	Techbridge web service	High	8.7	closed
V-004	Cleartext traffic enabled for app	Digital bank app	High	8.7	closed
V-005	Cleartext traffic enabled for app	Customer mobile app	High	8.7	closed
V-006	No stack canary value added to 4 binary stacks	Customer mobile app	High	7.5	closed
V-007	Debug configuration enabled	Digital banking app	High	7.5	closed
V-008	Openssl ccs innjection	Techbridge web service	High	7.4	closed
V-009	Insecure “webview”	Digital banking	High	7.4	closed

	implementation	app			
V-010	Directory traversal vulnerability	Techbridge web service	High	7.0	closed
V-011	Hash collision vulnerability	Digital banking app	Medium	5.5	open
V-012	Dangerous read/write permissions	Digital bank app	Medium	5.5	open
V-013	Apache server ETag information disclosure	Techbridge web service	Medium	5.3	open
V-014	Browsable directories	Digital bank app	Medium	5.3	closed
V-015	Debugging functions are enabled on the remote server	Techbridge web service	Medium	5.3	open
V-016	The web application's SQL backend can be identified	Techbridge web service	Medium	5.0	closed
V-017	Redirect vulnerability	Techbridge web service	Medium	4.7	closed
V-018	Assetlinks.json file	Customer mobile app	Medium	4.3	closed
V-019	Cross-site scripting vulnerability	Techbridge web service	Medium	4.3	closed
V-020	App can be installed on vulnerable unpatched android version	Customer mobile app	medium	4.0	open

V-021	App can be installed on vulnerable unpatched android version	Digital bank app	medium	4.0	open

7. DETAILED VULNERABILITY FINDINGS:

V-001: OBSOLETE END OF LIFE SERVER STACK

FIELD	DETAILS
Severity	Critical
CVSS Score	10.0
Affected Asset	Techbridge Web Service
CWE-ID	CWE-1104
Status	**Remediated**
Owner	Security Operations Team

DESCRIPTION:

The web server was running multiple completely unmaintained, End-of-Life (EOL) software components—including Apache 2.2.14, PHP 5.3.2, OpenSSL 0.9.8k, and Python 2.6.5. (Refer to evidence pack V-001 for scan output).

BUSINESS IMPACT:

Outdated operating systems, unpatched server software, and unmaintained plugins create open entry points for cybercriminals. This can result in malware injections, ransomware, complete server takeover, massive data breaches and heavy regulatory fines for non-compliance(GDPR violations).

REMEDIATION RECOMMENDATION:

Migrate away from EOL Apache 2.2 and PHP 5.3 to modern supported versions (Apache 2.4.x, PHP 8.x, OpenSSL 3.x).

V-002: REMOTE HOST VULNERABLE TO SQL INJECTION

FIELD	DETAILS
Severity	Critical
CVSS Score	9.3
Affected Asset	Techbridge Web Service
CWE-ID	CWE-929
Status	**Remediated**
Owner	Security Operations Team

DESCRIPTION:

The scanner was able to send specially crafted input to one or more endpoints and parameters on the remote host that resulted in an injection into a SQL query, allowing arbitrary SQL statements to be executed on the remote host (Refer to evidence pack V-002 for scan output).

BUSINESS IMPACT:

Attacker may bypass authentication and read confidential customer data, modify the remote database or even take control of the remote Operating System**.**

REMEDIATION RECOMMENDATION:

The application should be updated to use parameterized queries which prevent an attacker from injecting special characters that can be used to break out of the intended context and execute sql statements

V-003: WEB SERVER TRANSMITS CLEARTEXT CREDENTIALS

FIELD	DETAILS
Severity	High
CVSS Score	8.7
Affected Asset	Techbridge Web Service
CWE-ID	CWE-522
Status	**Remediated**
Owner	Security Operations Team

DESCRIPTION:

The remote web server contained several HTML form fields containing an input of type 'password' which transmit their information to a remote web server in cleartext (Refer to evidence pack V-003 for scan output).

BUSINESS IMPACT:

An attacker eavesdropping the traffic between web browser and server may obtain logins and passwords of valid users.

REMEDIATION RECOMMENDATION:

Make sure that every sensitive form transmits content over HTTPS.

V-004: CLEARTEXT TRAFFIC IS ENABLED FOR APP

FIELD	DETAILS
Severity	High
CVSS Score	8.7
Affected Asset	Digital banking app
CWE-ID	CWE-319
Status	**Remediated**
Owner	DevSecOps Lead

DESCRIPTION:

Clear text traffic was Enabled For App[android:usesCleartextTraffic=true]

BUSINESS IMPACT:

Lack of confidentiality, authenticity, and protections against tampering; a network attacker can eavesdrop on transmitted data and also modify it.

REMEDIATION RECOMMENDATION:

Enforce secure network traffic (HTTPS, FTPS) and disable cleartext traffic across the entire application**.**

V-005: CLEARTEXT TRAFFIC ENABLED FOR APP

FIELD	DETAILS
Severity	High
CVSS Score	8.7
Affected Asset	Customer mobile app
CWE-ID	CWE-319
Status	**Remediated**
Owner	DevSecOps Lead

DESCRIPTION:

Clear text traffic was Enabled For App [android:usesCleartextTraffic=true]

BUSINESS IMPACT:

Lack of confidentiality, authenticity, and protections against tampering; a network attacker can eavesdrop on transmitted data and also modify it.

REMEDIATION RECOMMENDATION:

Enforce secure network traffic (HTTPS, FTPS) and disable cleartext traffic across the entire application**.**

V-006: NO STACK CANARY VALUE ADDED TO FOUR BINARY STACKS

FIELD	DETAILS
Severity	High
CVSS Score	7.5
Affected Asset	Customer mobile app
CWE-ID	CWE-121
Status	**Remediated**
Owner	Mobile Engineering Lead

DESCRIPTION:

A **stack canary** is a secret, random security value placed on the program stack right before the function return pointer. If a hacker attempts a **stack buffer overflow attack** to overwrite the return address and hijack the app's execution flow, they will inevitably overwrite the canary value first.

Before the function exits, the system checks the canary. If the value has changed, the system knows a memory corruption attempt just occurred and **immediately terminates the app** to prevent malicious code execution.

BUSINESS IMPACT:

Stack canary being missing means the binary is highly vulnerable to memory corruption. If an attacker finds a way to feed overly long or malformed input into one of the app's native components, they could potentially execute **arbitrary code execution** attacks directly on the user's device (Refer to evidence pack V-006 for the four specific binary stacks affected).

REMEDIATION RECOMMENDATION:

Update app build configurations to turn on stack protection.

V-007: DEBUG CONFIGURATION ENABLED:

FIELD	DETAILS
Severity	High
CVSS Score	7.5
Affected Asset	Digital banking app
CWE-ID	CWE-919
Status	**Remediated**
Owner	Security Operations Team

DESCRIPTION:

The apk has been compiled with debugging features left turned on.

BUSINESS IMPACT:

When an application leaves debugging features enabled in a production build, it exposes the application to reverse engineering and runtime exploitation. An attacker or a malicious app on the same device can hook a debugger (like JDWP) into your running application. This allows them to step through code execution, inspect memory contents, dump sensitive variables, extract encryption keys, and manipulate the application's runtime behavior at will.

REMEDIATION RECOMMENDATION:

Ensure that release builds explicitly disable debugging**.**

V-008: OPENSSL CCS INJECTION

FIELD	DETAILS
Severity	High
CVSS Score	7.4
Affected Asset	Techbridge web service
CWE-ID	CWE-310
Status	**Remediated**
Owner	Security Operations Team

DESCRIPTION:

The Web server is running an outdated, highly vulnerable version of openssl, Nmap's built-in script (ssl-ccs-injection) successfully tested the target and confirmed that it is vulnerable to CVE-2014-0224 (Refer to evidence pack V-008 for scan output).

BUSINESS IMPACT:

vulnerability identified on port 443 (HTTPS) allows an unauthenticated Man-in-the-Middle (MitM) attacker to force the use of a zero-length master key in TLS sessions. An attacker positioned on the network can decrypt, modify, or hijack encrypted HTTPS traffic passing between clients and the web server.

REMEDIATION RECOMMENDATION:

OpenSSL patch deployment is strongly recommended

V-009: INSECURE "WEBVIEW" IMPLEMENTATION

FIELD	DETAILS
Severity	High
CVSS Score	7.4
Affected Asset	Digital banking app
CWE-ID	CWE-295
Status	**Remediated**
Owner	Security Operations Team

DESCRIPTION:

WebView ignores SSL Certificate errors and accept any SSL Certificate.

BUSINESS IMPACT:

This application is vulnerable to MITM attacks.

REMEDIATION RECOMMENDATION:

To keep the custom WebViewClient, ensure that you default to rejecting mistakes by invoking handler.cancel().

V-010: DIRECTORY TRAVERSAL VULNERABILITY:

FIELD	DETAILS
Severity	High
CVSS Score	7.0
Affected Asset	Techbridge Web Service
CWE-ID	CWE-22
Status	**Remediated**
Owner	Web platform owner

DESCRIPTION:

The remote web server hosted CGI scripts that failed to adequately sanitize request strings and were affected by directory traversal or local file inclusion vulnerabilities.

BUSINESS IMPACT:

By leveraging this issue, an attacker may be able to modify arbitrary files on the web server or execute commands and can lead to application takeover.

REMEDIATION RECOMMENDATION:

Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade.

V-011: HASH COLLITION VULNERABILITY

FIELD	DETAILS
Severity	Medium
CVSS Score	5.5
Affected Asset	Digital banking app
CWE-ID	CWE-327
Status	**Open**
Owner	Security Operations Team

DESCRIPTION:

The app utilizes a weak cryptographic hashing algorithm—most commonly MD5 or SHA-1—which is susceptible to collision attacks. In cybersecurity, a **collision** occurs when two entirely different pieces of input data produce the exact same hash output. The app checks hashes to verify that data hasn't been altered during transit or storage, a collision allows tampered data to pass through undetected.

BUSINESS IMPACT:

An attacker could replace a legitimate app file, update, or dependency with a malicious one that has been carefully crafted to generate the exact same hash value. The app would then accept the malicious file as valid.

REMEDIATION RECOMMENDATION:

Re-sign the application using a secure, modern signature hashing algorithm (like SHA-256).

V-012: DANGEROUS READ/WRITE PERMISSIONS

FIELD	DETAILS
Severity	Medium
CVSS Score	5.5
Affected Asset	Digital banking app
CWE-ID	CWE-276
Status	**Open**
Owner	DevSecOps lead

DESCRIPTION:

Allows an application to read from/write to external storage, as well read contact address stored on phone.

BUSINESS IMPACT:

Malicious apps can use this to send personal customer data to other people**.**

REMEDIATION RECOMMENDATION:

Remove the permission from AndroidManifest.xml. Instead, use internal storage methods like Context.getFilesDir() or Context.getExternalFilesDir(). These folders are private to your app and require zero permissions.

V-013: APACHE SERVER ETAG HEADER INFORMATION DISCLOSURE

FIELD	DETAILS
Severity	Medium
CVSS Score	5.3
Affected Asset	Techbridge Web Service
CWE-ID	CWE-200
Status	**Open**
Owner	Security Operations Team

DESCRIPTION:

The remote web server is affected by an information disclosure vulnerability due to the ETag header providing sensitive information that could aid an attacker, such as the inode number of requested files.

BUSINESS RISK:

Attacker could use sensitive information to launch attack on web server.

REMEDIATION RECOMMENDATION:

Modify the HTTP ETag header of the web server to not include file inodes in the ETag header calculation.

V-014: BROWSABLE WEB DIRECTORIES ON WEB SERVER

FIELD	DETAILS
Severity	Medium
CVSS Score	5.3
Affected Asset	Techbridge Web Service
CWE-ID	CWE-548
Status	**Remediated**
Owner	Security Operations Team

DESCRIPTION:

Multiple Nessus plugins identified directories on the web server that are browsable.

BUSINESS IMPACT:

Potential unauthorized access to sensitive resources

REMEDIATION RECOMMENDATION:

Make sure that browsable directories do not leak confidential information or give access to sensitive resources. Additionally, use access restrictions or disable directory indexing for any that do.

DEBUGGING FUNCTIONS ENABLED ON REMOTE SERVER

FIELD	DETAILS
Severity	Medium
CVSS Score	5.3
Affected Asset	Techbridge Web Service
CWE-ID	CWE-16
Status	**Open**
Owner	Security Operations Team

DESCRIPTION:

The remote web server accepts the TRACE and/or TRACK HTTP requests. These are standard HTTP debugging methods designed to loop back exactly what a user sends to a server so developers can see if any proxies or firewalls are altering the request headers**.**

BUSINESS IMPACT:

Attackers use this to bypass cookie protections (HttpOnly). By tricking a victim's browser into sending a TRACE request, they can capture sensitive authentication cookies or authorization headers in the server's looped-back response (a technique known as **Cross-Site Tracking** or **XST**).

REMEDIATION RECOMMENDATION:

Disable these HTTP methods.

V-016: SQL BACKEND CAN BE IDENTIFIED

FIELD	DETAILS
Severity	Medium
CVSS Score	5.0
Affected Asset	Techbridge Web Service
CWE-ID	CWE-200
Status	**Remediated**
Owner	Security Operations Team

DESCRIPTION:

At least one web application hosted on the remote web server is built on a SQL backend that Nessus was able to identify by looking at error messages.

BUSINESS IMPACT:

This kind of information may help an attacker fine-tune attacks against the application and its backend.

REMEDIATION RECOMMENDATION:

Filter out error messages.

V-017: OPEN REDIRECT VULNERABILITY

FIELD	DETAILS
Severity	Medium
CVSS Score	4.7
Affected Asset	Techbridge Web Service
CWE-ID	CWE-601
Status	**Mitigated**
Owner	Security Operations Team

DESCRIPTION:

The remote web server hosts a perl script that is affected by an open redirect vulnerability**.**

BUSINESS IMPACT:

An attacker can exploit this issue to conduct phishing attacks by tricking users into visiting malicious websites.

REMEDIATION RECOMMENDATION:

To avoid the open redirect vulnerability, parameters of the application script/program must be validated before sending 302 HTTP code (redirect) to the client browser. Implement safe redirect functionality that only redirects to relative URI's, or a list of trusted domains.

V-018: APP LINK ASSETLINKS.JSON FILE NOT FOUND

FIELD	DETAILS
Severity	Medium
CVSS Score	4.3
Affected Asset	Customer mobile app
CWE-ID	CWE-20
Status	**Remediated**
Owner	DevSecOps Lead

DESCRIPTION:

App Link assetlinks.json file was not found[android:name=com.app.damnvulnerablebank.CurrencyRates]

BUSINESS IMPACT:

If this file is missing or incorrectly configured for the App Link host/domain, a malicious app can hijack such URLs. This may lead to phishing attacks, leak sensitive data in the URI, such as PII, OAuth tokens, magic link/password reset tokens and more.

REMEDIATION RECOMMENDATION:

verify the App Link domain by hosting the assetlinks.json file and enabling verification via [android:autoVerify="true"] in the Activity intent-filter.

V-019: CROSS-SITE SCRIPTING ATTACKS VULNERABILITY

FIELD	DETAILS
Severity	Medium
CVSS Score	4.3
Affected Asset	Techbridge Web Service
CWE-ID	CWE-79
Status	**Remediated**
Owner	Web Platform Owner

DESCRIPTION:

The CGI Scripts hosted on remote web server makes it prone to cross-site scripting attacks.A Cross-Site Scripting (XSS) attack is a critical vulnerability where an attacker injects malicious scripts (usually JavaScript) into a trusted website or web application.

Instead of attacking the server directly, the attacker uses the vulnerable website as a vehicle to deliver the malicious code straight to the browser of unsuspecting users. Because the browser believes the script comes from a trusted source, it executes it without question.

BUSINESS IMPACT:

by leveraging this issue, attackers may be able to cause HTML and script code to be executed in user browser and redirect them to another location or transfer sensitive data across.

REMEDIATION RECOMMENDATION:

Restrict access to the application, contact vendor for a patch or upgrade to address cross-site scripting vulnerabilities.

V-020 & V021: APPS CAN BE INSTALLED ON A VULNERABLE UNPATCHED ANDROID VERSION

FIELD	DETAILS
Severity	Medium
CVSS Score	4.0
Affected Asset	Customer mobile app & Digital banking app
CWE-ID	CWE-1104
Status	**Open**
Owner	Mobile Engineering Lead

DESCRIPTION:

App can be installed on a vulnerable unpatched Android version 4.1-4.1.2.

BUSINESS IMPACT:

This application can be installed on an older version of android that has multiple unfixed vulnerabilities. These devices won't receive reasonable security updates from Google.

REMEDIATION RECOMMENDATION:

Support an Android version => 10, API 29 to receive reasonable security updates.

8. REMEDIATION VALIDATION/RETESTING

FINDING	RETEST DATE	RESULT	ASSESSOR
V-001	12/9/26	Fixed	Security operations team
V-002	10/9/26	Fixed	Security operations team
V-003	10/9/26	Fixed	Security operations team
V-004	9/9/26	Fixed	DevSecOps lead
V-005	9/9/26	Fixed	DevSecOps lead
V-006	9/9/26	Fixed	Mobile engineering lead
V-007	10/9/26	Fixed	Security operations team
V-008	9/9/26	Fixed	Security operations team
V-009	10/9/26	Fixed	Security operations team
V-010	10/9/26	Fixed	Web platform owner
V-011	10/9/26	Not fixed	Security operations team
V-012	10/9/26	Not fixed	DevSecOps lead
V-013	10/9/26	Not fixed	Security operations team
V-014	10/9/26	Fixed	Security operations team
V-015	9/9/26	Not fixed	Security operations team
V-016	10/9/26	Fixed	Security operations team
V-017	3/9/26	Partially fixed/ Mitigated	Security operations team
V-018	11/9/26	Fixed	DevSecOps lead
V-019	12/9/26	Fixed	Web platform

			owner
V-020	12/9/26	Not fixed	Mobile engineering lead
V-021	12/9/26	Not fixed	Mobile engineering lead

9. CONCLUSION

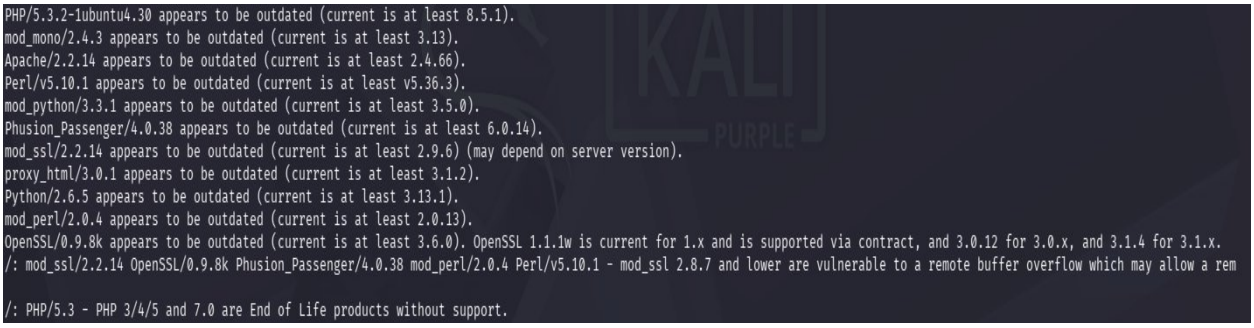
Techbridge consulting limited must implement these controls to establish a sustainable vulnerability management programme to maintain improvement to their subsequent overall security posture:

- Consistent weekly vulnerability scanning of all applications and systems.
- A centralised vulnerability register.
- Bi-weekly remediation tracking of closed vulnerabilities.
- Clearly defined team to handle vulnerability management cycle.

APPENDICES:

EVIDENCE PACK-

V-001



V-002

```
During testing for cookie manipulation vulnerabilities,
 SQL errors were noticed, suggesting that the scripts / parameters
listed below may also be vulnerable to SQL Injection (SQLi).

-------- request  --------
GET /owaspbricks/content-1/index.php?id=<script>document.cookie="testztjr=7325;"</script> HTTP/1.1
Host: 10.202.248.206
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
Accept-Language: en
Connection: Keep-Alive
Pragma: no-cache
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*
------------------------

-------- output --------

Warning: mysql_fetch_array() expects parameter 1 to be resource, b [...]
Database query failed: You have an error in your SQL syntax; check the m
anual that corresponds to your MySQL server version for the right syntax
 to use near '=<script>document.cookie="testztjr=7325;"</script> LIMIT 1
' at line 1<br/>
</fieldset></p><br/>
</div><br/><br/><br/>
------------------------
```

```
During testing for script injection vulnerabilities,
 SQL errors were noticed, suggesting that the scripts / parameters
listed below may also be vulnerable to SQL Injection (SQLi).

-------- request  --------
GET /owaspbricks/content-2/index.php?user=msgbox("foo");window.alert('bar'); HTTP/1.1
Host: 10.202.248.206
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
Accept-Language: en
Connection: Keep-Alive
Pragma: no-cache
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*
------------------------

-------- output --------

Warning: mysql_fetch_array() expects parameter 1 to be resource, b [...]
Database query failed: You have an error in your SQL syntax; check the m
anual that corresponds to your MySQL server version for the right syntax
 to use near 'bar');'' at line 1<br/>
</fieldset>
</p><br/>
------------------------

-------- request  --------
GET /mutillidae/includes/pop-up-help-context-gene [...]
```

V-003

```
Destination Page: /phpBB2/login.php?sid=24335b8f9732802b671c95006c7ab836

Page : /railsgoat/signup
Destination Page: /railsgoat/users

Page : /railsgoat/login
Destination Page: /railsgoat/sessions

Page : /shepherd/login.jsp
Destination Page: /shepherd/login

Page : /ghost/
Destination Page: /ghost/submit.php

Page : /bodgeit/login.jsp
Destination Page: /bodgeit/login.jsp

Page : /cyclone/signin
Destination Page: /cyclone/sessions

Page : /cyclone/signup
Destination Page: /cyclone/users

Page : /AppSensorDemo/login.jsp
Destination Page: /AppSensorDemo/Login

Page : /cgi-bin/courierwebadmin.cgi
Destination Page: /cgi-bin/courierwebadmin.cgi

Page : /wordpress/wp-login.php
Destination Page: /wordpress/wp-login.php

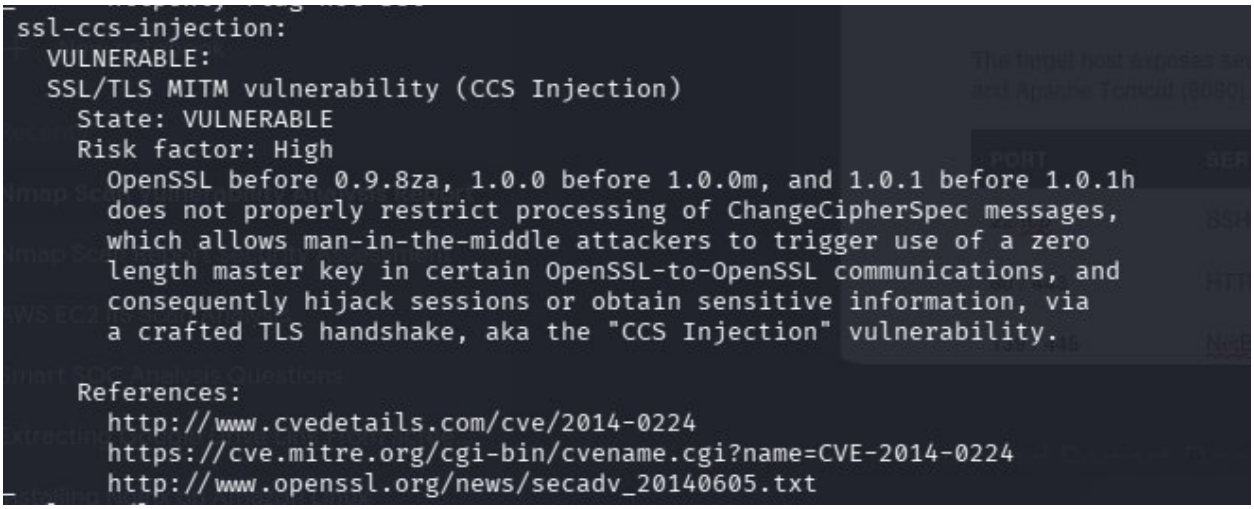
Page : /phpmyadmin/index.php
Destination Page: /phpmyadmin/index.php
```

V-006

“arm64-v8a/libtool- checker.so”, “x86_64/libtool- checker.so”, “arm64-v8a/libtool- checker.so”,

x86_64/libtool- checker.so.

V-008



V-010

```
Using the GET HTTP method, Nessus found that :

+ The following resources may be vulnerable to directory traversal (write access) :

+ The 'sort' parameter of the /getboo/ CGI :

/getboo/?sortOrder=alphabet&sort=popularity../../../../../../../../../..
/tmp

-------- output --------
</body>
</html>
<!-- Cached: Fri, 02 Oct 2026 10:34:50 -0400 -->


-------- vs --------
</body>
</html>
<!-- Cached: Fri, 02 Oct 2026 10:34:51 -0400 -->
------------------------
```

V-013

```
Nessus was able to determine that the Apache Server listening on
port 80 leaks the servers inode numbers in the ETag HTTP
Header field :

  Source                : ETag: "45f13-6da3-51c22f5365e00"
  Inode number          : 286483
  File size             : 28067 bytes
  File modification time : Jul. 31, 2015 at 02:55:52 GMT
```

V-014

```
The following directories are browsable :

http://10.202.248.206/MCIR/includes/
http://10.202.248.206/WackoPicko/css/
http://10.202.248.206/WackoPicko/css/blueprint/
http://10.202.248.206/WackoPicko/css/blueprint/plugins/
http://10.202.248.206/WackoPicko/css/blueprint/src/
http://10.202.248.206/WackoPicko/pictures/
http://10.202.248.206/WackoPicko/users/
http://10.202.248.206/bWAPP/images/
http://10.202.248.206/bWAPP/stylesheets/
http://10.202.248.206/cgi-bin/
```

10.202.248.206 18

```
http://10.202.248.206/dvwa/dvwa/
http://10.202.248.206/dvwa/dvwa/css/
http://10.202.248.206/dvwa/dvwa/images/
http://10.202.248.206/dvwa/dvwa/includes/
http://10.202.248.206/dvwa/dvwa/js/
http://10.202.248.206/gallery2/modules/
http://10.202.248.206/gallery2/modules/icons/
http://10.202.248.206/gallery2/modules/icons/iconpacks/
http://10.202.248.206/gallery2/modules/icons/iconpacks/paularmstrongdesigns/
http://10.202.248.206/gallery2/themes/
http://10.202.248.206/gallery2/themes/matrix/
http://10.202.248.206/ghost/guides/
http://10.202.248.206/ghost/stylesheet/
http://10.202.248.206/gtd-php/themes/
http://10.202.248.206/gtd-php/themes/default/
http://10.202.248.206/gtd-php/themes/menu_sidebar/
http://10.202.248.206/images/
http://10.202.248.206/mutillidae/documentation/
http://10.202.248.206/mutillidae/images/
http://10.202.248.206/mutillidae/images/Hints_files/
http://10.202.248.206/mutillidae/images/gritter/
http://10.202.248.206/mutillidae/includes/
http://10.202.248.206/mutillidae/includes/hints-level-1/
http://10.202.248.206/mutillidae/includes/hints-level-2/
http://10.202.248.206/mutillidae/includes/test/
http://10.202.248.206/mutillidae/includes/test/testoutput/
http://10.202.248.206/mutillidae/styles/
http://10.202.248.206/mutillidae/styles/ddsmoothmenu/
http://10.202.248.206/mutillidae/styles/gritter/
http://10.202.248.206/mutillidae/webservices/
http://10.202.248.206/mutillidae/webservices/rest/
http://10.202.248.206/mutillidae/webservices/rest/test/
http://10.202.248.206/mutillidae/webservices/rest/test/testoutput/
```

V-015

```
To disable these methods, add the following lines for each virtual
host in your configuration file :

    RewriteEngine on
    RewriteCond %{REQUEST_METHOD} ^(TRACE|TRACK)
    RewriteRule .* - [F]

Alternatively, note that Apache versions 1.3.34, 2.0.55, and 2.2
support disabling the TRACE method natively via the 'TraceEnable'
directive.

Nessus sent the following TRACE request : \n\n------------------------------ snip
 ------------------------------\nTRACE /Nessus2112415215.html HTTP/1.1
Connection: Close
Host: 10.202.248.206
Pragma: no-cache
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*
Accept-Language: en
Accept-Charset: iso-8859-1,*,utf-8

------------------------------ snip ------------------------------\n\nand received the
 following response from the remote server :\n\n------------------------------ snip
 ------------------------------\nHTTP/1.1 200 OK
Date: Fri, 02 Oct 2026 13:59:20 GMT
Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-
Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k
 Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1
Keep-Alive: timeout=15, max=100
Connection: Keep-Alive
Transfer-Encoding: chunked
Content-Type: message/http

TRACE /Nessus2112415215.html HTTP/1.1
```

V-016

```
The web application appears to be based on MySQL

This information was leaked by these URLs :
http://10.202.248.206/
```

V-017

```
Nessus was able to verify the issue using the following URL :

 http://10.202.248.206/awstats/awredir.pl?url=http://www.example.com
```

V-019

```
Using the GET HTTP method, Nessus found that :

+ The following resources may be vulnerable to cross-site scripting (quick test) :

+ The 'player' parameter of the /vicnum/cgi-bin/jotto1.pl CGI :

/vicnum/cgi-bin/jotto1.pl?player="><object%20type="text/html"%20data="ht
tp://www.example.com/include.html"></object>

-------- output --------
</table>
<hr size="3" color="#FF00FF">
<h2>Welcome "><object type="text/html" data="http://www.example.com/incl
ude.html"></object> - the computer has chosen a five letter word.
<p>
Enter your five character guess and then click on the GUESS button [...]
------------------------

+ The 'message' parameter of the /yazd/bay/error.jsp CGI :

/yazd/bay/error.jsp?message=<IMG%20SRC="javascript:alert(104);">

-------- output --------
<pre>

<font color="#ff0000"><IMG SRC="javascript:alert(104);"></font>

</pre>
------------------------

+ The 'name' parameter of the /zapwave/active/xss/xss-form-url.jsp CGI :

/zapwave/active/xss/xss-form-url.jsp?name=<IMG%20SRC="javascript:alert(1
04);">

-------- output --------
Only a GET is vulnerable, not a POST.
<H3>Example</H3>
The URL 'name' parameter is <IMG SRC="javascript:alert(104);"><br/><br/>
```